POOJA KIRAN | SECURITY ENGINEERING

Reproducible Regression Harness for Machine-Learning Security Tools

Contract-Validated Adapters Catching Cross-Repo Breakage Before It Ships

Source inventory: 848edf0506178f4e386c5007df9ae72001b5a238

Test snapshot: 848edf0506178f4e386c5007df9ae72001b5a238

CI run 38298946029 | initiated 2026-10-12 UTC | Apache-2.0

https://github.com/poojakira/mlsec-benchmark-suite

82
tests passed in cited CI

90.76%
statement coverage at cited CI

1.00
real HF adapter F1 on 5 committed fixtures

3 / 0
true positives / false positives in that fixture test

CONTRIBUTION

- A contract-validated regression harness that wraps ML security tools in typed in-process adapters, runs them against versioned fixtures, and fails pytest on schema drift - with a hard, labeled separation between REAL product adapters and a synthetic smoke-test scaffold.

IMPLEMENTED METHOD

- 1. 1 Load (fixtures) -> 2 Adapt (in-proc) -> 3 Run (tool) -> 4 Validate (schema) -> 5 Assert (contract) -> 6·7 Report (Markdown)

LIMITATIONS AND EVIDENCE BOUNDARY

- Validates contracts/format, not real-world accuracy.
- run-smoke numbers are synthetic (seeded PRNG).
- Fixture coverage is finite; gaps possible.
- Adapters can go stale if a tool changes internals.
- Real adapter gating requires sibling install.

SCOPED EVIDENCE

- Cited Python 3.12 CI: 82 passed, 1 skipped; 90.76% statement coverage, same test job.
- October 12 real-adapter job 11497020804: genuine scanner integration test passed; CLI logged precision=recall=F1=1.0. Test assertions cover 3 known-bad and 2 known-good configs, with 3 TP, 0 FP, 0 FN.
- Historical results/real_hf_scanner.json is absent from the inspected tree. This claim uses the dated CI job, not an invented replacement artifact.
- Synthetic run-smoke values are seeded schema plumbing, not measured detector accuracy; no arbitrary smoke-score bar is shown.

REPRODUCTION

- git checkout 848edf0506178f4e386c5007df9ae72001b5a238
- Install the documented development dependencies; run python -m pytest tests/ -q. Use the cited job configuration when reproducing coverage.
- Benchmark data, adapters and environment requirements are separate; consult poster/13_reproducibility.md and the claim ledger.

Dated tests and committed fixtures do not establish universal detection, production deployment or an SLO.